GITLAB INC.

Évaluation des risques de cybersécurité et feuille de route d'amélioration de la gouvernance de la sécurité de GitLab

Rapport principal - Livrable 1

EBIOS RM > PSSI > Analyse d'écarts > Feuille de route

Contrôle du document

Rubrique	Détail
Référence du document	GRC-GL-2026-01
Version / statut	1.0 - Projet pour relecture
Date	5 octobre 2026
Date limite des preuves	4 octobre 2026 (sources publiques uniquement)
Classification	Confidentiel - livrable d'analyste
Type d'étude	Évaluation externe, sur sources publiques, du risque cyber et de la gouvernance de la sécurité
Méthodologie	EBIOS Risk Manager (ANSSI) - PSSI - traitement du risque - analyse d'écarts - feuille de route
Objet	GitLab.com, GitLab Dedicated, produit auto-hébergé, Duo / Duo Agent Platform

Déclaration de périmètre
Ce document n'est ni un audit interne, ni un test d'intrusion, ni une évaluation de vulnérabilités, ni un audit de certification ISO/IEC 27001, et il n'affirme pas que GitLab n'est pas sûr. La mention « non vérifiable publiquement » ne signifie jamais « absent ». Tous les scores de risque sont des jugements d'analyste fondés sur des sources publiques et doivent être validés avec les données internes de GitLab.

Sommaire

Si cette page apparaît vide, ouvrez le fichier dans Microsoft Word et choisissez « Mettre à jour le champ » (ou acceptez l'invite de mise à jour) pour générer la table des matières.

1. Synthèse de direction

Ce que nous avons évalué. Nous avons réalisé une évaluation externe, sur sources publiques, du risque cyber et de la gouvernance de GitLab, la plateforme DevSecOps utilisée par plus de 50 millions d'utilisateurs enregistrés et, selon son 10-K de l'exercice 2026, par plus de la moitié du Fortune 100. Nous avons appliqué EBIOS Risk Manager pour identifier les risques qui comptent, les avons traduits en une PSSI (politique de sécurité des systèmes d'information) de 32 exigences, avons comparé ces exigences à ce que GitLab démontre publiquement, et avons construit une feuille de route de 24 mois de 26 actions.

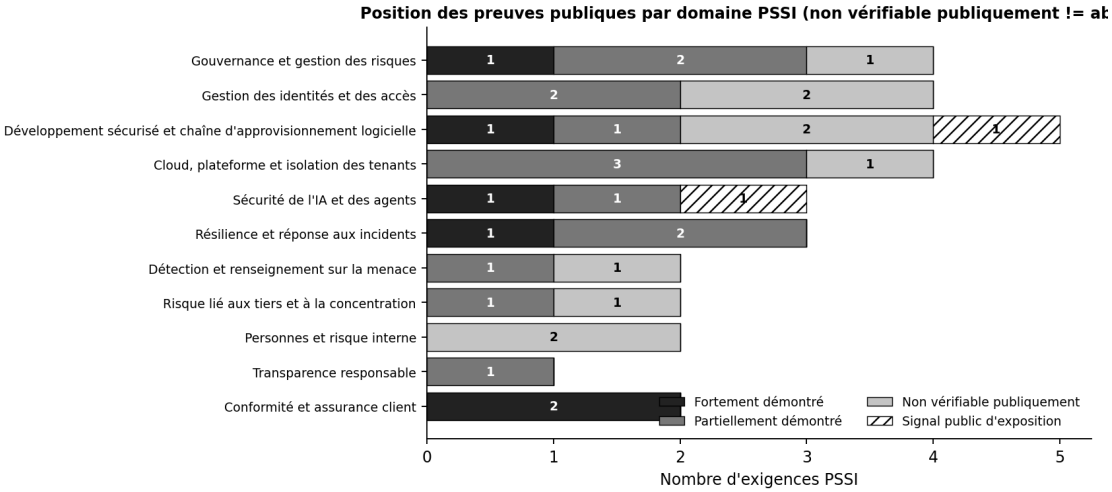
Pourquoi GitLab est un objet de risque particulier. GitLab ne se contente pas de stocker des données clients : elle exécute le code des clients sur une infrastructure partagée, détient leur code source et leurs secrets CI/CD, livre du logiciel à des milliers d'installations auto-hébergées, et intègre désormais des agents d'IA autonomes dans les pipelines. Une seule compromission a donc un effet multiplicateur sur la chaîne d'approvisionnement.

Constats principaux

- **13 risques** ont été évalués : 2 Critiques, 4 Élevés, 6 Moyens, 1 Faible. Score inhérent moyen 12.9/25.
- **Critiques :** R-01 compromission d'identité privilégiée (20) et R-02 exploitation de vulnérabilités produit critiques (20). Le second est corroboré par des événements publics : CVE-2023-7028 (CISA KEV, 2024) et CVE-2026-85706 (CVSS 10, inscrite KEV, exploitée en quelques jours après le correctif du 10 sept. 2026), suivies d'autres correctifs RCE critiques le 23 sept. 2026.
- **Élevés :** détournement des fonctions d'IA et des agents (16), écart d'adoption des correctifs côté auto-hébergé (16), compromission de la chaîne d'approvisionnement logicielle (15) et interruption majeure de service (15).
- **Point de vigilance de gouvernance :** le 10-K de GitLab indique que le RSSI est parti le 26 févr. 2026 et qu'un intérimaire est en place. Le programme est décrit comme se poursuivant normalement ; nous le traitons comme un risque de continuité, pas comme une défaillance.
- **Les points forts sont réels et visibles :** SOC 2 Type 2, ISO 27001/27017/27018, ISO 42001, FedRAMP Moderate pour Dedicated for Government, un Trust Center public, un bug bounty HackerOne, des CVE avec CWE, une correction SaaS le jour même, des Game Days de reprise trimestriels et un handbook public d'une grande franchise.

Posture de sécurité actuelle (vue des preuves publiques)

Sur 32 exigences PSSI : **6 fortement démontrées**, **14 partiellement démontrées**, **10 non vérifiables publiquement** et **2 présentent un signal public d'exposition** (développement sécurisé des composants à haut risque ; privilèges et traitement des sorties des agents d'IA). **Non vérifiable publiquement ne signifie pas absent** : par exemple la provenance des builds, l'hygiène des identités machines, le type de MFA des collaborateurs et la chasse aux menaces ne sont simplement pas décrits dans les sources publiques.



Recommandations prioritaires

1. **0-3 mois :** établir la continuité de la gouvernance pendant la transition du RSSI ; inventorier et hiérarchiser les accès privilégiés ; imposer un MFA résistant à l'hameçonnage pour le Tier-0 ; codifier et répéter un playbook de vulnérabilités de classe KEV ; modéliser les menaces des agents Duo et des périmètres MCP ; lancer un pack d'indicateurs pour le conseil.
2. **3-6 mois :** intégrité vérifiable du build et des releases ; programme d'identités machines et de secrets ; test indépendant du plan de contrôle Dedicated ; validation de la reprise régionale de bout en bout et publication de RTO/RPO mesurés.
3. **6-12 mois :** ingénierie de détection sur les chemins d'attaque prioritaires ; publication des indicateurs de délai de correction ; durcissement des dépendances et des runners ; sauvegardes immuables.
4. **12-24 mois :** accès de production juste-à-temps, red teaming continu des agents, architecture de résilience et extension des certifications (FedRAMP High).

Effet attendu

Si la feuille de route est exécutée, la somme des scores de risque passe de 168 à 106 (37 % de réduction). Les deux risques Critiques passent à Moyen/Élevé ; R-02 reste Élevé car l'exposition aux vulnérabilités du produit est inhérente à une plateforme d'exécution de code et se gère plutôt qu'elle ne s'élimine.

2. Introduction

2.1 Contexte et objectifs

La question à laquelle ce projet répond est : compte tenu de l'activité, des actifs, de l'écosystème et du paysage de menaces de GitLab, quels risques de cybersécurité doit-elle prioriser, quelles exigences de sécurité doivent les encadrer, et comment doit-elle améliorer sa posture dans le temps ?

- Identifier et classer les principaux risques cyber de GitLab avec EBIOS RM.
- Traduire ces risques en un ensemble cohérent d'exigences de sécurité (PSSI).
- Comparer les exigences à ce que GitLab démontre publiquement (analyse d'écarts).
- Définir une feuille de route d'amélioration priorisée, avec responsables et échéances.

2.2 Pourquoi GitLab

GitLab est une entreprise cotée, entièrement en télétravail et open-core, d'une transparence inhabituelle : son handbook, ses documents d'architecture, ses notes de version, son Trust Center et ses dépôts SEC exposent suffisamment d'informations pour permettre une évaluation externe pertinente. Elle se situe aussi à un point sensible de la chaîne d'approvisionnement logicielle.

2.3 Périmètre

Dans le périmètre : GitLab.com SaaS multi-tenant (plateforme de production, runners CI partagés, registres, fonctions d'IA). ; GitLab Dedicated, y compris le plan de contrôle Switchboard et les comptes AWS des tenants exploités par GitLab. ; Ingénierie produit et chaîne de livraison produisant le logiciel auto-hébergé et le code SaaS. ; Capacités d'IA (GitLab Duo / Duo Agent Platform) et dépendances envers les fournisseurs de modèles. ; Gouvernance de la sécurité, identité des collaborateurs et administration pouvant atteindre les éléments ci-dessus. ; Tiers et sous-traitants que GitLab déclare publiquement comme participant à la fourniture du service.

Hors périmètre : Instances auto-hébergées exploitées par les clients (responsabilité du client ; considérées uniquement comme effet d'écosystème). ; Dépôts, pipelines et configurations propres aux clients. ; Systèmes, configurations et personnels internes de GitLab (aucun accès interne ; sources publiques uniquement). ; JiHu (coentreprise chinoise, entité consolidée VIE) - citée comme entité de l'écosystème, non évaluée en profondeur. ; Tests techniques de toute nature (ni scan, ni test d'intrusion, ni exploitation).

2.4 Hypothèses

- Les déclarations publiques de GitLab sont prises pour argent comptant sauf contradiction par d'autres preuves publiques ; elles ne sont pas testées de façon indépendante.
- Les responsables nommés dans cette étude sont des rôles proposés ; l'organisation réelle de GitLab peut différer.
- Les scores (impact, vraisemblance) sont des jugements d'analyste ancrés dans des preuves publiques citées et des échelles définies.
- L'autorité de décision sur les risques est supposée être le RSSI sous la supervision du comité d'audit.

2.5 Limites

- Pas d'accès interne : la conception des mesures et leur efficacité opérationnelle ne peuvent pas être vérifiées.
- Certains documents du handbook et de conception peuvent retarder sur la réalité (le 10-K de GitLab dit lui-même que le handbook peut ne pas toujours être à jour).

- Certains détails de vulnérabilités de septembre 2026 proviennent de sources secondaires (notées B/C dans le registre de preuves) et doivent être vérifiés dans les notes de version de GitLab.
- Aucun test technique d'aucune sorte n'a été effectué.

3. Méthodologie

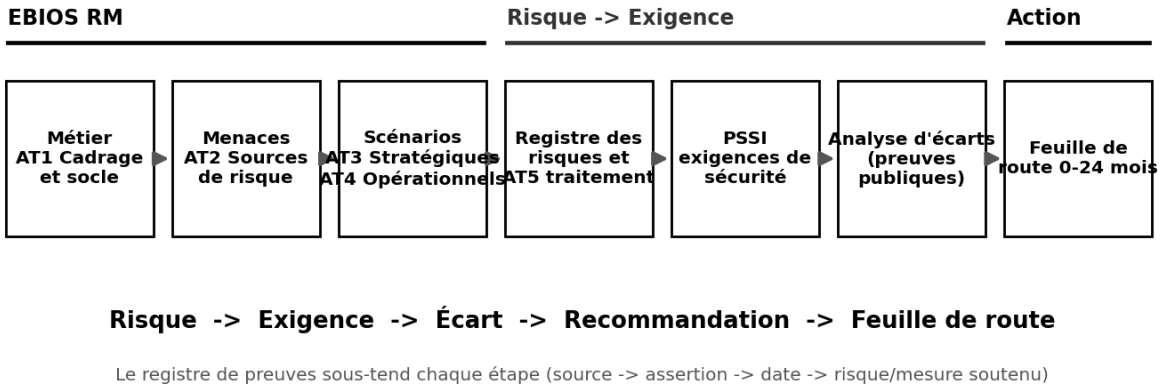


Figure 1 - Du métier à la feuille de route : EBIOS RM -> PSSI -> analyse d'écarts -> feuille de route.

3.1 EBIOS Risk Manager

EBIOS RM (ANSSI, 2018) est une méthode d'analyse de risque par scénarios en cinq ateliers. Nous l'avons suivie avec une adaptation : une échelle de 1 à 5 pour l'impact et la vraisemblance (au lieu de l'échelle à 4 niveaux du guide) afin de permettre une matrice 5x5 conventionnelle.

Atelier	Question traitée	Production principale dans cette étude
1 - Cadrage et socle	Que faut-il protéger, et que pourrait-il arriver de grave ?	7 valeurs métier, 17 biens supports, 10 événements redoutés, socle de sécurité
2 - Sources de risque	Qui attaquerait, et pourquoi ?	9 sources de risque, 12 couples source/objectif (11 retenus)
3 - Scénarios stratégiques	Par quels chemins de l'écosystème ?	Niveaux de menace de l'écosystème (11 parties prenantes), 11 scénarios stratégiques
4 - Scénarios opérationnels	Comment, concrètement, et avec quelle vraisemblance ?	10 scénarios de chemins d'attaque avec références ATT&CK et vraisemblance
5 - Traitement du risque	Que fait-on ?	Registre des risques (13 risques), décisions de traitement, risque résiduel, dispositif de suivi

3.2 Échelles

Niveau	Impact	Vraisemblance (24 mois)
1	Négligeable - Aucun effet mesurable sur les clients, le chiffre d'affaires ou la conformité ; absorbé par l'exploitation normale.	Rare - Moins de 5 % de chances d'occurrence significative sur 24 mois.
2	Mineur - Effet limité et de courte durée sur quelques clients ; aucune conséquence réglementaire ou contractuelle.	Peu probable - 5 à 20 % sur 24 mois.
3	Modéré - Impact client perceptible ou conséquence contractuelle/de conformité ; récupérable par le processus normal de gestion d'incident.	Possible - 20 à 50 % sur 24 mois.
4	Majeur - Impact multi-clients, dégradation significative du service ou exposition de données ; obligations de notification et atteinte notable à la réputation.	Probable - 50 à 80 % sur 24 mois, ou événements comparables déjà observés dans le secteur.
5	Critique - Impact systémique, multi-clients ou sur la chaîne d'approvisionnement ; compromission massive de données/propriété intellectuelle ou perte prolongée de la plateforme ; significatif pour la valeur de l'entreprise.	Quasi certain - Plus de 80 % sur 24 mois, ou occurrence continue.

Priorité	Score (I x V)	Signification
Critique	>= 20	Attention au niveau du conseil ; traitement immédiat (0-3 mois).
Élevé	15-19	Plan de traitement porté par un dirigeant ; premières actions sous 3-6 mois.

Priorité	Score (I x V)	Signification
Moyen	8-14	Géré dans le programme de sécurité courant ; actions sous 6-12 mois.
Faible	<= 7	Surveillance ; acceptation ou traitement opportuniste.

3.3 PSSI, analyse d'écarts, traitement et feuille de route

- **PSSI** - chaque risque retenu est traduit en exigences (« doit »), regroupées en 11 domaines, chacune avec responsable, fréquence de revue, indicateurs et correspondance avec les référentiels (ISO 27002:2022, NIST CSF 2.0, SOC 2).
- **Analyse d'écarts** - chaque exigence est comparée aux preuves publiques et reçoit un niveau de preuve (ci-dessous). Elle mesure la *démontrabilité publique*, pas l'efficacité réelle des mesures.
- **Traitement du risque** - décision (réduire / transférer / accepter) par risque avec cible résiduelle.
- **Feuille de route** - indice de priorité = 2 x score du risque lié le plus élevé + 4 x urgence + 2 x (6 - effort) ; P1 >= 62, P2 48-61, P3 < 48 ; phasage 0-3, 3-6, 6-12, 12-24 mois avec responsables, dépendances et indicateurs.

Niveau	Libellé	Signification
3	Fortement démontré	Une assurance indépendante ou une documentation primaire détaillée est publiquement disponible.
2	Partiellement démontré	Une politique, une déclaration ou une conception est publique, mais l'efficacité opérationnelle ne peut pas être vérifiée de l'extérieur.
1	Non vérifiable publiquement	Aucune preuve publique pertinente dans les sources examinées. Cela ne signifie PAS que la mesure est absente.
0	Signal public d'exposition	Des événements ou travaux de recherche publics indiquent une exposition résiduelle dans ce domaine. Cela ne prouve PAS que la mesure est absente ou inefficace.

Non vérifiable publiquement n'est pas absent
Une mesure que GitLab ne décrit pas publiquement peut exister et bien fonctionner. L'analyse d'écarts indique ce qu'un client ou un conseil peut *démontrer de l'extérieur*, ce dont dépend l'assurance par un tiers.

3.4 Méthodologie de preuve

36 sources ont été examinées et consignées dans le registre de preuves (livrable 5) avec URL, date, note de fiabilité (A primaire, B secondaire réputée, C indicative), une assertion paraphrasée et les risques/mesures soutenus. Aucune source de note C n'est utilisée seule.

4. Aperçu de GitLab

4.1 Activité et clients

Dimension	Faits publics (source)
Activité	Plateforme d'orchestration intelligente pour le DevSecOps : gestion de code source, CI/CD, sécurité et conformité, agents d'IA ; modèle open-core (E-01)
Échelle	CA FY26 955,2 M$ (+26 %) ; plus de 50 M d'utilisateurs enregistrés ; 10 682 clients de base ; clients dans 159 pays ; plus de 70 % de l'ARR issu du secteur public et des grandes entreprises (E-01)
Clients	Plus de la moitié du Fortune 100 ; services financiers, technologie, santé, administrations, télécoms, industrie (E-01)
Options de déploiement	GitLab.com SaaS multi-tenant ; auto-hébergé ; GitLab Dedicated SaaS mono-tenant dont Dedicated for Government (FedRAMP Moderate) (E-01, E-06)
Niveau de service critique	SLA de disponibilité mensuelle de 99,9 % pour les services SaaS couverts (E-01)
Effectif	~2 580 membres dans 60 pays ; télétravail complet ; embauches directes, PEO et prestataires (E-01)
IA	Duo et Duo Agent Platform (GA janv. 2026) ; dépendance à des fournisseurs de modèles tiers (E-01, E-02, E-09)
Gouvernance de la sécurité	Programme piloté par le RSSI avec plus de 120 praticiens ; RSSI parti le 26 févr. 2026, intérim en place ; ERM piloté par l'Audit interne ; supervision du comité d'audit (E-03)

4.2 Écosystème technologique et dépendances

- **GitLab.com** s'exécute sur Google Cloud (us-east1, plusieurs zones) ; sauvegardes en stockage multi-régions ; architecture Cells en cours (E-12, E-13, E-14).
- **GitLab Dedicated** utilise un compte AWS dédié et un VPC isolé par tenant, un plan de contrôle Switchboard, Geo pour la reprise et PrivateLink optionnel (E-10, E-11).
- **Les sous-traitants** incluent Google, AWS, Zendesk, Elasticsearch, Snowflake, OpenAI et des fournisseurs de support externalisé (E-09).
- **Chaîne d'approvisionnement logicielle** : code open-core, plus de 5 200 contributeurs, milliers de dépendances, releases mensuelles (E-01, E-02).
- **Le code fourni par les clients s'exécute sur l'infrastructure de GitLab** (runners partagés) - une caractéristique déterminante reconnue dans le 10-K (E-02).

4.3 Mesures de sécurité documentées publiquement

Domaine de mesure	Ce qui est public	Preuves
SOC 2 Type 2 (Sécurité, Confidentialité, Disponibilité) - GitLab.com et Dedicated	En place ; rapports 2025 et lettre de continuité 2025-26 listés sur le Trust Center	E-05
ISO/IEC 27001 / 27017 / 27018 (sécurité du cloud et données personnelles dans le cloud)	Certificat listé sur le Trust Center ; couvre GitLab.com et Dedicated	E-05, E-07, E-08
ISO/IEC 42001:2023 (système de management de l'IA)	Certification annoncée sur le Trust Center	E-05, E-06
FedRAMP Moderate (Dedicated for Government) ; High en perspective	Listé comme actuel / prévu dans le handbook	E-06, E-07
GitLab Control Framework rapproché de SOC 2, ISO 27001, PCI, FedRAMP	Décrit publiquement	E-36
Politique de gestion des accès (moindre privilège, approbations, revues, retrait des droits, exceptions)	Document contrôlé public avec références de contrôles de type NIST	E-16, E-17
Divulgation des vulnérabilités (bug bounty HackerOne, security.txt, CVE avec CWE, correctifs mensuels + critiques)	Documenté publiquement et visiblement en fonctionnement	E-18, E-19, E-22

Domaine de mesure	Ce qui est public	Preuves
Engagement CISA Secure by Design (MFA, réduction des mots de passe par défaut, correctifs, politique de divulgation)	Rapport d'avancement publié en juin 2025 ; déploiement du MFA par défaut annoncé comme à venir	E-18
Reprise après sinistre (Game Days trimestriels, sauvegardes multi-régions, tests de restauration quotidiens de la base, objectifs RTO/RPO)	Politique publiée dans le handbook ; SLA Dedicated avec RTO/RPO	E-12, E-13, E-14, E-15
Gouvernance de la sécurité (programme piloté par le RSSI, plus de 120 praticiens, ERM piloté par l'Audit interne, supervision du comité d'audit)	Publié dans l'Item 1C du 10-K	E-03, E-04

5. Évaluation EBIOS RM

5.1 Atelier 1 - Cadrage et socle de sécurité

Le périmètre de l'étude et l'autorité de décision sont définis en section 2. Nous avons identifié sept valeurs métier et les biens supports qui les portent.

ID	Valeur métier	Description	Besoin principal
VM-01	Fourniture du service SaaS GitLab.com	Plateforme hébergée multi-tenant pour dépôts, CI/CD, registres et gestion de projet, utilisée par des millions d'utilisateurs ; SLA de disponibilité mensuelle de 99,9 %.	Disponibilité, Intégrité
VM-02	Fourniture du service GitLab Dedicated	SaaS mono-tenant pour clients régulés (dont Dedicated for Government), comptes AWS par tenant, plan de contrôle Switchboard.	Confidentialité, Intégrité, Disponibilité
VM-03	Ingénierie produit et chaîne de livraison	Code source, infrastructure de build et de release, dépôts de paquets et éléments de signature produisant le logiciel GitLab pour le SaaS et l'auto-hébergé (open-core, milliers de contributeurs externes).	Intégrité, Authenticité
VM-04	Contenus et secrets des clients	Code source des clients, variables CI/CD, jetons d'accès, clés de déploiement, artefacts de conteneurs/paquets et données de projet hébergés par GitLab.	Confidentialité, Intégrité
VM-05	Capacités d'IA (Duo / Duo Agent Platform)	Assistants et agents autonomes d'IA agissant sur le code et les pipelines des clients, dépendant de fournisseurs de modèles tiers.	Intégrité, Confidentialité
VM-06	Confiance, assurance et éligibilité aux marchés	Certifications et attestations (SOC 2, ISO 27001/27017/27018/42001, FedRAMP), Trust Center, accès aux marchés publics et régulés.	Authenticité, Traçabilité
VM-07	Opérations de sécurité, identité des collaborateurs et administration	Réponse aux incidents, gestion et divulgation des vulnérabilités, identité des collaborateurs, outils d'administration et de support pour ~2 600 personnes en télétravail complet, y compris du personnel PEO et prestataire.	Confidentialité, Intégrité

Événements redoutés

ID	Événement redouté	DIC	Gravité	Justification
ER-01	Exfiltration à grande échelle de dépôts, jetons et secrets clients depuis GitLab.com	C	5	Le code source et les secrets CI de plus de 10 000 clients payants (dont plus de 50 % du Fortune 100) pourraient permettre la compromission en aval des clients ; notification de violation et exposition contractuelle.
ER-02	Modification malveillante du code produit, du build ou des artefacts de release de GitLab	I	5	Une release empoisonnée atteint le SaaS et chaque client auto-hébergé ; événement classique de chaîne d'approvisionnement logicielle à portée systémique.
ER-03	Indisponibilité prolongée de GitLab.com ou perte de données irrécupérable	D	4	Les pipelines de livraison des clients s'arrêtent ; crédits SLA, perte de clients, atteinte à la réputation. La reprise après perte régionale repose sur reconstruction et restauration.
ER-04	Compromission du plan de contrôle Dedicated ou de l'isolation des tenants	C, I	5	Les tenants régulés et gouvernementaux partagent un plan opérateur ; une compromission du plan de contrôle serait multi-tenant par construction.
ER-05	Fonction d'IA ou agent détourné pour fuiter des données ou injecter du code malveillant	C, I	4	Les agents agissent avec les privilèges de l'utilisateur sur du code privé ; l'injection de prompt peut en faire des canaux d'exfiltration ou de falsification de code.
ER-06	Perte ou expiration de certifications clés et de l'éligibilité aux marchés régulés	Authenticité	3	Des opinions d'audit avec réserves, une transition ISO manquée ou des difficultés FedRAMP bloqueraient les ventes publiques et régulées.
ER-07	Vulnérabilité critique du produit massivement exploitée avant que les clients puissent corriger	C, I, D	4	Les parcs auto-hébergés sont exposés dans les heures suivant un correctif ; GitLab subit l'impact de réputation et de support même si l'instance est gérée par le client.
ER-08	Prise de contrôle d'identités privilégiées de collaborateurs ou d'administration	C, I	5	L'identité privilégiée est le facilitateur commun de ER-01, ER-02 et ER-04.

ID	Événement redouté	DIC	Gravité	Justification
ER-09	Runners CI partagés détournés pour un impact inter-tenants ou un abus massif de ressources	C, D	4	Le code des clients s'exécutant sur l'infrastructure de GitLab, une défaillance d'isolation a des conséquences inter-tenants.
ER-10	Divulgation involontaire d'informations sensibles via la transparence radicale	C	3	Le handbook public, les trackers d'issues et la feuille de route ouverte peuvent fuiter des détails opérationnels sensibles ; le 10-K signale lui-même ce risque.

Socle de sécurité

Le socle (section 4.3) montre un programme mature, avec une assurance externe. Points de vigilance reportés aux ateliers suivants : déclarations d'édition ISO, transition du RSSI, validation de la reprise régionale et achèvement du MFA par défaut.

5.2 Atelier 2 - Sources de risque

ID	Source de risque	Objectif	Capacité	Décision
SR-1	Acteurs étatiques / menaces persistantes avancées (APT)	Espionnage, pré-positionnement, accès au code de clients gouvernementaux et de défense	Très élevée	Retenue
SR-2	Cybercriminalité organisée (extorsion, vol d'identifiants et de secrets)	Gain financier : rançon, revente de secrets/accès, cryptominage	Très élevée	Retenue
SR-3	Exploiteurs opportunistes de masse et opérateurs de botnets	Gains rapides sur des vulnérabilités nouvellement divulguées	Très élevée	Retenue
SR-4	Interne malveillant ou contraint (salarié, prestataire, PEO ou personnel de support externalisé)	Gain financier, rancœur, contrainte	Moyenne	Retenue
SR-5	Contributeur open source malveillant / mainteneur compromis	Insertion de porte dérobée, levier sur la chaîne d'approvisionnement	Moyenne	Retenue
SR-6	Hacktivistes	Perturbation, publicité	Moyenne	Retenue (faible)
SR-7	Utilisateurs malveillants de la plateforme (abus de l'offre gratuite et du calcul partagé)	Calcul gratuit, anonymat, attaque latérale d'autres tenants	Élevée	Retenue
SR-8	Adversaires assistés par IA / acteurs d'injection de prompt	Vol de données et manipulation de code via les agents d'IA	Élevée	Retenue
SR-9	Concurrents et renseignement économique hostile	Intelligence économique	Faible	Non retenue

Couples source de risque / objectif visé

Couple	Source	Objectif visé	Événements redoutés	Pertinence
C-01	SR-1	Voler code source, secrets et architectures de clients à forte valeur via GitLab.com	ER-01, ER-08	4
C-02	SR-2	Extorquer ou monétiser des secrets et accès volés en compromettant des identités privilégiées	ER-08, ER-01	4
C-03	SR-5	Insérer une porte dérobée dans le produit ou la chaîne de release de GitLab pour un accès en aval	ER-02	3
C-04	SR-1	Se pré-positionner dans la chaîne de build et de release de GitLab pour de futures opérations de chaîne d'approvisionnement	ER-02	3
C-05	SR-3	Exploiter en masse les vulnérabilités produit nouvellement divulguées (auto-hébergé et SaaS)	ER-07, ER-01	4
C-06	SR-8	Exfiltrer du code privé ou manipuler du code via les assistants et agents d'IA	ER-05	3
C-07	SR-7	Détourner les runners partagés pour voler des ressources ou s'évader vers d'autres tenants	ER-09	3

Couple	Source	Objectif visé	Événements redoutés	Pertinence
C-08	SR-4	Détourner un accès administratif ou de support légitime pour vol ou sabotage	ER-08, ER-01	2
C-09	SR-6	Perturber la disponibilité de GitLab.com à des fins de publicité	ER-03	2
C-10	SR-2	Détruire ou chiffrer des données de production à des fins d'extorsion	ER-03	2
C-11	SR-1	Compromettre le plan de contrôle Dedicated pour atteindre des tenants régulés	ER-04	2
C-12	SR-9	Intelligence économique sur les feuilles de route internes	ER-10	1

Onze couples sur douze ont été retenus. Les couples retenus de pertinence la plus élevée (4) sont le vol étatique de code de clients à forte valeur (C-01), la compromission cybercriminelle d'identités privilégiées (C-02) et l'exploitation de masse de nouvelles vulnérabilités (C-05).

5.3 Atelier 3 - Scénarios stratégiques

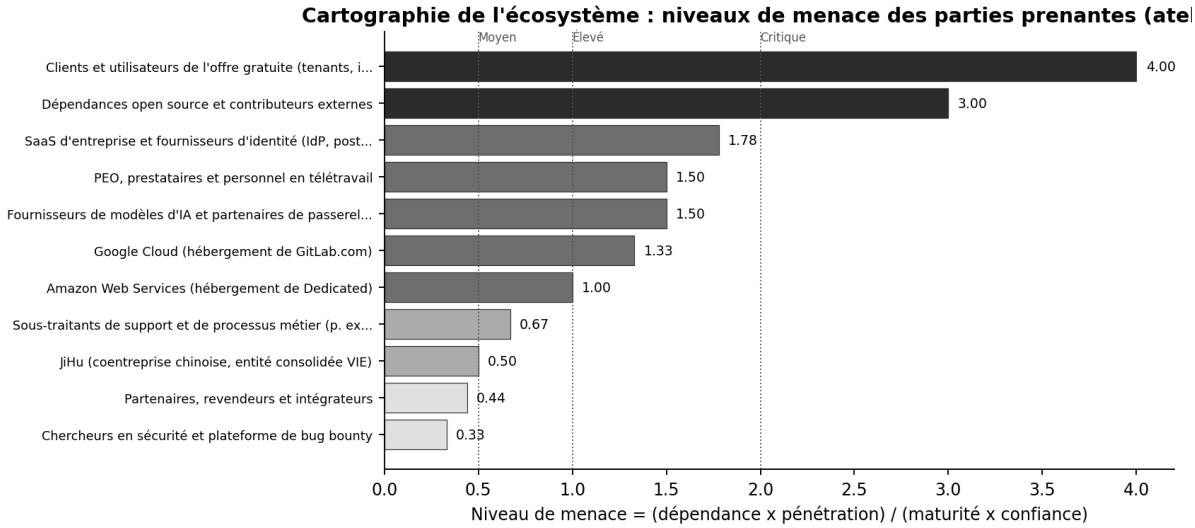


Figure 2 - Niveau de menace d'une partie prenante = (dépendance x pénétration) / (maturité x confiance).

Deux groupes de parties prenantes atteignent le niveau Critique parce que la plateforme leur accorde structurellement peu de confiance : les contributeurs/dépendances externes et les clients/utilisateurs de l'offre gratuite qui exécutent du code sur l'infrastructure de GitLab. Les fournisseurs d'identité et SaaS d'entreprise, les fournisseurs de modèles d'IA, le modèle d'effectif et les deux hyperscalers sont Élevés.

ID	Scénario stratégique	Événements	Gravité	Chemin dans l'écosystème
SS-01	Compromission d'identité privilégiée conduisant à un accès de production et à une exfiltration massive	ER-08, ER-01	5	SaaS d'entreprise et fournisseurs d'identité ; postes d'un personnel en télétravail
SS-02	Compromission de la chaîne d'approvisionnement logicielle du produit GitLab	ER-02	5	Contributeurs et dépendances open source ; outillage de build/release
SS-03	Exploitation d'une vulnérabilité produit critique (zero-day ou N-day)	ER-01, ER-07	5	Parcs auto-hébergés des clients ; fenêtre de correction de GitLab.com
SS-04	Une compromission ou panne d'un cloud ou sous-traitant se propage aux services GitLab	ER-03, ER-01	4	Google Cloud, AWS, fournisseurs d'IA, sous-traitants de support
SS-05	Détournement d'agents d'IA par injection de prompt indirecte ou jetons sur-dimensionnés	ER-05	4	Fournisseurs de modèles d'IA ; contenus clients traités par les agents
SS-06	Compromission du plan de contrôle Dedicated	ER-04	5	AWS ; opérateurs Switchboard
SS-07	Attaque destructrice, DDoS ou défaillance régionale avec reprise lente	ER-03	4	Google Cloud ; infrastructures DDoS

ID	Scénario stratégique	Événements	Gravité	Chemin dans l'écosystème
SS-08	Usage abusif d'un accès administratif ou de support par un interne	ER-08, ER-01	4	PEO, prestataires, support externalisé
SS-09	Abus de runners partagés et évasion entre tenants	ER-09	4	Clients et utilisateurs de l'offre gratuite
SS-10	Défaut de continuité de gouvernance affaiblissant l'assurance et la certification	ER-06	3	Auditeurs ; organismes de certification
SS-11	Reconnaissance et fuite via handbook, issues et feuille de route publics	ER-10	3	Communauté publique ; concurrents

5.4 Atelier 4 - Scénarios opérationnels

Dix scénarios de chemins d'attaque ont été détaillés selon la séquence EBIOS Connaître - Rentrer - Trouver - Exploiter. Les tableaux d'étapes complets avec références ATT&CK figurent dans le livrable 2 (onglet AT4_Operationnels) ; la synthèse ci-dessous présente la vraisemblance, les mesures publiques et les points de vigilance.

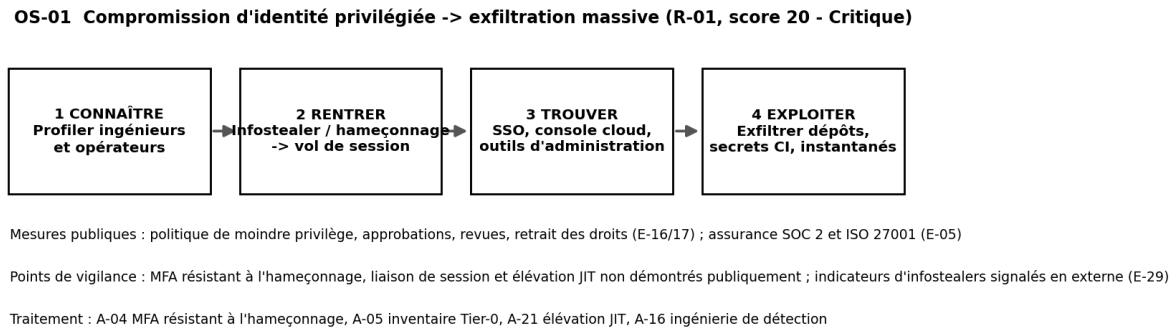


Figure 3 - OS-01, le scénario opérationnel au score le plus élevé.

OS	Scénario	Risque	Vraisemblance	Mesures publiques observées	Faiblesse / point de vigilance
OS-01	Le vol de session d'un ingénieur privilégié conduit à l'extraction de données de production	R-01	4	Politique d'accès au moindre privilège avec approbations, revues et retrait des droits (E-16, E-17) ; assurance SOC 2 / ISO 27001 (E-05) ; équipe de sécurité de plus de 120 personnes et supervision du comité d'audit (E-03).	La protection des sessions privilégiées (MFA résistant à l'hameçonnage, liaison à l'appareil, durée de jeton courte) et l'élévation juste-à-temps ne sont pas démontrées publiquement. Des données de notation externe signalent des détections d'infostealers sur des systèmes associés à l'organisation (E-29, indicateur seulement).
OS-02	Un mainteneur ou une dépendance compromis empoisonne la chaîne de release	R-03	3	Revue de code et transparence open source ; programme HackerOne (E-18) ; rythme de releases mensuelles avec correctifs de sécurité (E-01, E-19).	La provenance, la signature, les builds hermétiques et l'approbation de release à deux personnes ne sont pas documentées publiquement dans les sources examinées. Le 10-K cite les attaques de chaîne d'approvisionnement via le code communautaire comme risque significatif (E-02).
OS-03	Une vulnérabilité pré-authentification est instrumentalisée dans les heures suivant la publication du correctif	R-02	4	GitLab.com corrigé au moment de la release (E-22) ; divulgation coordonnée, CVE avec CWE et releases de correctifs critiques (E-18, E-19) ; rétroportage vers d'anciennes branches (E-25).	Failles critiques récurrentes : CVE-2023-7028 (KEV, 2024) et CVE-2026-85706 (CVSS 10, KEV, sept. 2026, exploitée en quelques jours), plus d'autres correctifs RCE critiques le 23 sept. 2026 (E-20, E-22, E-23, E-24, E-26). L'adoption des correctifs par les clients échappe au contrôle de GitLab (E-21).
OS-04	L'injection de prompt indirecte oriente Duo ou un agent vers l'exfiltration de code privé	R-06	4	Certification ISO 42001 (E-05) ; AI Transparency Center (E-05) ; fournisseur de protection contre l'injection de prompt listé comme sous-traitant (E-09) ; corrections de failles Duo signalées (E-27).	Une recherche indépendante a démontré l'exfiltration de code privé (E-27) ; les correctifs de septembre 2026 incluent une désérialisation CVSS 9,9 atteignable via l'accès à Duo Chat et une faille d'application du périmètre des jetons MCP (E-23, E-26). L'autonomie croissante des agents étend la surface (E-01).
OS-05	Des identifiants d'opérateur ou une faille du plan de contrôle donnent une portée multi-tenant dans Dedicated	R-07	2	Isolation mono-tenant, comptes AWS et VPC par tenant, reprise Geo, PrivateLink optionnel (E-10, E-11) ; SOC 2 et FedRAMP Moderate pour Government (E-05, E-06).	Le durcissement du plan de contrôle, les limites de rayon d'impact entre tenants et le modèle d'accès des opérateurs ne sont pas détaillés publiquement.
OS-06	Une perte régionale ou une attaque destructrice rencontre une reprise régionale non validée	R-05	3	Game Days trimestriels, sauvegardes multi-régions et tests de restauration quotidiens de la base (E-12) ; SLA Dedicated avec RTO/RPO (E-15) ; travaux d'architecture Cells (E-14).	Les documents de conception notent une exploitation mono-région et que la reprise régionale n'avait pas été validée de bout en bout lors de la rédaction (E-13). L'état actuel et l'immutabilité des sauvegardes ne sont pas indiqués publiquement.
OS-07	Un job malveillant sur un runner partagé tente l'évasion ou la capture de secrets	R-09	3	Le 10-K reconnaît le risque d'exécution de code et des mesures d'atténuation comme les limites de l'offre gratuite (E-02) ; couverture SOC 2 du SaaS (E-05).	La conception de l'isolation des runners et les indicateurs de détection d'abus ne sont pas vérifiés publiquement dans les sources examinées.
OS-08	Un incident chez un sous-traitant ou hyperscaler se propage à GitLab	R-04	3	Liste publique de sous-traitants avec notification des changements (E-09) ; ISO 27017/27018 (E-05).	La profondeur de la diligence, les limites de concentration et les plans de sortie ne sont pas vérifiables publiquement ; le 10-K indique que GitLab peut être tenue responsable des défaillances de tiers (E-02).
OS-09	Un interne ou un agent de support externalisé abuse de son accès légitime	R-08	2	Approbations d'accès, revues et retrait à la cessation d'emploi (E-16) ; effectif PEO et prestataire reconnu (E-01).	Le filtrage des candidats, la surveillance des internes privilégiés et les contraintes du support externalisé ne sont pas vérifiables publiquement.
OS-10	Un attaquant exploite le handbook et les issues publics pour y trouver des détails opérationnels exploitables	R-13	3	La transparence est délibérée et bornée par des sections internes du handbook ; le 10-K reconnaît la « transparence responsable » (E-02).	Les garde-fous automatisés pour le contenu public (détection de secrets/PII, portes de classification) ne sont pas documentés publiquement.

5.5 Atelier 5 - Traitement du risque

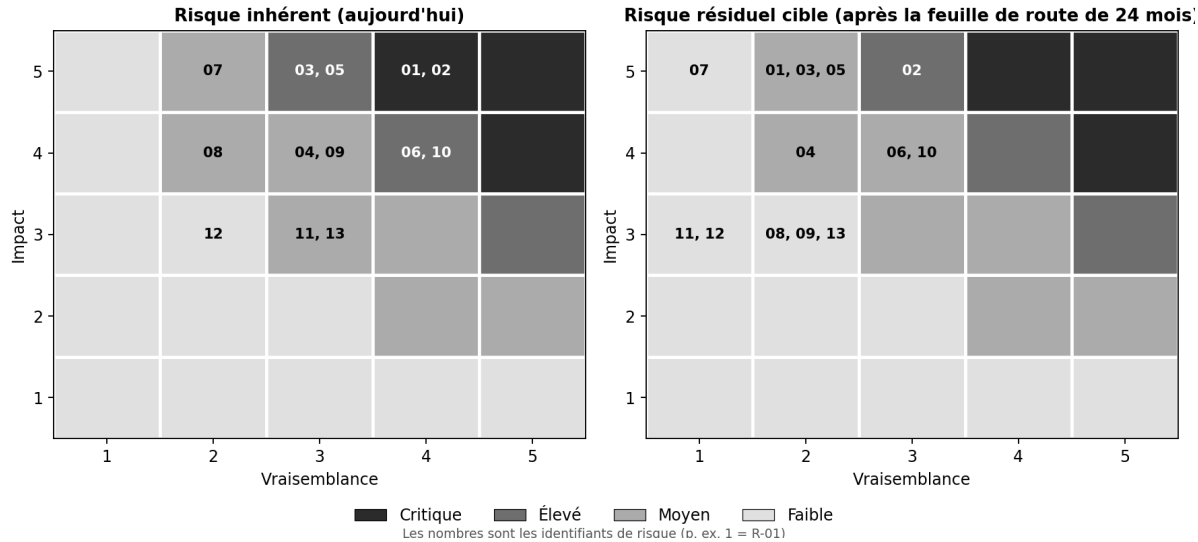


Figure 4 - Cartes de chaleur du risque inhérent et du risque résiduel cible.

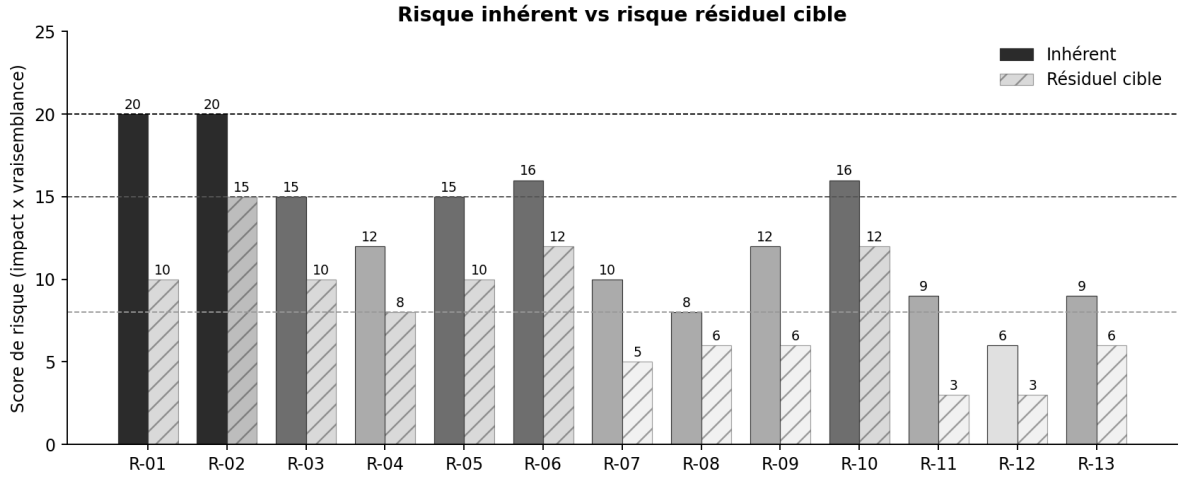


Figure 5 - Réduction du risque par risque après la feuille de route de 24 mois.

Les décisions de traitement, cibles résiduelles et autorités d'acceptation figurent en section 6 et dans le livrable 2 (onglet AT5_Traitement). Le dispositif de suivi est le suivant :

Activité	Fréquence	Responsable	Périmètre
Revue du registre des risques	Trimestrielle	Gouvernance de la sécurité	Réévaluer R-01 à R-13 ; ajouter les risques émergents (p. ex. nouvelles classes d'attaques d'IA).
Mise à jour complète EBIOS RM	Annuelle, ou après un incident majeur / changement d'architecture	RSSI	Rejouer les ateliers 2 à 5 ; mettre à jour les niveaux de menace de l'écosystème.
Suivi de la feuille de route	Comité de pilotage mensuel ; comité d'audit trimestriel	PMO sécurité	Avancement vs jalons, tendance des indicateurs, risque de dépendances.
Actualisation des preuves publiques	Semestrielle	Analyste / Assurance sécurité	Mettre à jour le registre de preuves ; réévaluer les éléments « non vérifiables publiquement ».
Déclencheur de renseignement sur la menace	Continue	SecOps / Renseignement sur la menace	Les ajouts KEV, campagnes sectorielles et nouvelles classes de CVE déclenchent une revue hors cycle.

6. Registre des risques

Risque inhérent = impact x vraisemblance. Le risque résiduel est la cible après la feuille de route de 24 mois. La version active avec formules figure dans le livrable 2.

ID	Scénario de risque	Impact	Vraisemblance	Score	Priorité	Traitement	Résiduel	Niveau résiduel
R-01	Compromission d'identité privilégiée	5	4	20	Critique	Réduire	5x2 = 10	Moyen
R-02	Exploitation de vulnérabilités produit critiques	5	4	20	Critique	Réduire	5x3 = 15	Élevé
R-03	Compromission de la chaîne d'approvisionnement logicielle du produit GitLab	5	3	15	Élevé	Réduire	5x2 = 10	Moyen
R-04	Défaillance ou compromission de tiers et de fournisseurs cloud	4	3	12	Moyen	Réduire + Transférer	4x2 = 8	Moyen
R-05	Interruption majeure de service ou perte de données	5	3	15	Élevé	Réduire	5x2 = 10	Moyen
R-06	Détournement des fonctions d'IA et des agents	4	4	16	Élevé	Réduire	4x3 = 12	Moyen
R-07	Compromission du plan de contrôle Dedicated ou de l'isolation des tenants	5	2	10	Moyen	Réduire	5x1 = 5	Faible
R-08	Abus d'accès privilégié ou de support par un interne	4	2	8	Moyen	Réduire	3x2 = 6	Faible
R-09	Abus des runners CI partagés et évasion entre tenants	4	3	12	Moyen	Réduire	3x2 = 6	Faible
R-10	Écart d'adoption des correctifs exposant les clients auto-hébergés et la réputation de GitLab	4	4	16	Élevé	Réduire	4x3 = 12	Moyen
R-11	Défaut de continuité de la gouvernance de la sécurité	3	3	9	Moyen	Réduire	3x1 = 3	Faible
R-12	Expiration ou érosion des certifications et de l'éligibilité aux marchés régulés	3	2	6	Faible	Réduire + Accepter le résiduel	3x1 = 3	Faible
R-13	Sur-divulgation due à la transparence radicale	3	3	9	Moyen	Réduire	3x2 = 6	Faible

Justification des risques

ID	Description	Pourquoi cette vraisemblance (preuves publiques)	Preuves
R-01	Compromission d'identités de collaborateurs ou d'administration (y compris vol de session/jeton) donnant accès à la production, aux organisations cloud, aux opérateurs Dedicated ou aux éléments de signature.	Les campagnes d'infostealers et de vol de session sont courantes contre les équipes d'ingénierie distantes ; les notations externes signalent des détections d'infostealers liées à l'organisation ; les mesures de sessions privilégiées ne sont pas démontrées publiquement.	E-01, E-16, E-17, E-29, E-03
R-02	Une faille critique de GitLab (lecture de fichier pré-auth, désérialisation, RCE CI/CD) est exploitée contre GitLab.com, Dedicated ou la base auto-hébergée.	Deux failles GitLab inscrites au KEV en 30 mois (CVE-2023-7028 ; CVE-2026-85706 avec exploitation en quelques jours) et d'autres correctifs RCE critiques le 23 sept. 2026.	E-20, E-22, E-23, E-24, E-26, E-32
R-03	Du code ou un artefact malveillant est introduit via les contributeurs, dépendances, build ou infrastructure de release.	Modèle open-core avec plus de 5 200 contributeurs et forte utilisation de dépendances ; les attaques de chaîne d'approvisionnement sont répandues dans le secteur ; mesures d'intégrité de build non démontrées publiquement.	E-01, E-02
R-04	Une violation ou panne chez Google Cloud, AWS, les fournisseurs de modèles d'IA ou les sous-traitants de support affecte les services ou données de GitLab.	Forte dépendance à deux hyperscalers et à plusieurs fournisseurs d'IA/support ; concentration et plans de sortie non vérifiables publiquement.	E-02, E-09, E-10, E-12
R-05	Panne prolongée de GitLab.com, attaque destructrice ou défaillance régionale avec reprise lente ou incomplète.	Exploitation mono-région décrite dans les documents de conception, reprise régionale historiquement non validée de bout en bout ; atténuée par les Game Days, sauvegardes multi-régions et tests de restauration quotidiens.	E-12, E-13, E-14, E-15, E-01
R-06	Injection de prompt, agents/jetons sur-privilégiés ou faiblesses de la chaîne d'approvisionnement de l'IA conduisent à des fuites de données ou modifications de code malveillantes.	Des recherches publiées ont déjà démontré l'exfiltration ; les agents autonomes étendent la surface ; les correctifs de septembre 2026 touchent Duo, GraphQL et les périmètres MCP.	E-02, E-23, E-26, E-27
R-07	L'accès opérateur ou une faille du plan de gestion donne une portée multi-tenant dans GitLab Dedicated.	Une conception d'isolation robuste et le contrôle des clients régulés réduisent la vraisemblance, mais l'impact est multi-tenant par construction.	E-10, E-11, E-06
R-08	Un salarié, prestataire, personnel PEO ou de support externalisé abuse d'un accès légitime.	Les modèles d'effectif larges accroissent l'exposition ; une politique d'accès et des mesures de retrait des droits existent.	E-01, E-16, E-09
R-09	Des jobs malveillants sortent de l'isolation, capturent des secrets ou détournent du calcul partagé.	L'exécution du code client est inhérente au produit ; l'abus de l'offre gratuite est un schéma persistant.	E-02, E-05
R-10	Les clients ne corrigent pas (ou exécutent des versions non supportées) après divulgation, entraînant une exploitation de masse et une atteinte à la réputation de GitLab.	Deux semaines après la faille KEV de 2024, des milliers d'instances restaient vulnérables ; en 2026, des correctifs ont été rétroportés vers des branches en fin de vie.	E-21, E-25, E-22
R-11	Une transition de direction et une croissance rapide réduisent la clarté de la responsabilité des risques, le reporting d'indicateurs et le rythme d'assurance.	Poste de RSSI laissé vacant le 26 févr. 2026 avec un intérimaire en place ; programme décrit comme se poursuivant normalement.	E-03, E-04, E-31
R-12	Transitions de normes manquées, écarts de périmètre ou constats avec réserves compromettent les ventes publiques et régulées.	Portefeuille de certifications solide, mais les pages publiques mélangent des éditions ISO et FedRAMP High reste prévu.	E-05, E-06, E-07, E-30
R-13	Le handbook, les issues et la feuille de route publics fuitent des détails opérationnels ou de sécurité, ou des secrets.	La transparence est une valeur centrale et le 10-K signale l'exactitude du handbook et les conséquences involontaires comme un risque.	E-02

7. PSSI - exigences de sécurité

La PSSI traduit le registre des risques en 32 exigences réparties en 11 domaines. La politique autonome (livrable 3) contient le texte complet, les indicateurs, les cycles de revue et la gouvernance ; ci-dessous figure la synthèse avec traçabilité vers les risques.

Exemple illustré

EBIOS constate : compromission de compte privilégié (R-01, score 20).

PSSI IAM-01 : les accès privilégiés doivent être fortement authentifiés, au moindre privilège, juste-à-temps, revus chaque trimestre, surveillés et révoqués sous 24 h.

Indicateurs : % de comptes privilégiés avec MFA résistant à l'hameçonnage ; % revus ; délai moyen de révocation.

ID	Exigence	Risques traités	Responsable (proposé)	Revue	Principaux indicateurs
GOV-01	Leadership et responsabilité de la sécurité	R-11, R-01, R-02	Comité d'audit / DG	Trimestrielle	Jours sans RSSI titulaire (cible : 0 sans plan de continuité); % de risques critiques avec un responsable exécutif nommé
GOV-02	Intégration de la gestion des risques	R-11	RSSI / Audit interne	Annuelle (registre : trimestrielle)	% de risques avec une décision de traitement à jour; % de risques résiduels formellement acceptés
GOV-03	Gestion des politiques et des exceptions	R-11, R-12	Assurance sécurité	Annuelle	% de politiques revues dans les délais; Nombre d'exceptions ouvertes au-delà de leur échéance
GOV-04	Indicateurs de sécurité et reporting au conseil	R-11, R-02	Gouvernance de la sécurité	Trimestrielle	Pack d'indicateurs trimestriel livré à l'heure; % d'indicateurs avec cible et responsable
IAM-01	Accès privilégiés	R-01, R-07, R-08, R-03	Responsable Identités et Accès	Trimestrielle	% de comptes privilégiés couverts par un MFA résistant à l'hameçonnage (cible 100 %); % de comptes privilégiés revus le trimestre écoulé (cible 100 %)
IAM-02	Authentification des collaborateurs	R-01, R-08	Responsable Identités et Accès / IT	Semestrielle	% de comptes de collaborateurs sous SSO+MFA; % de connexions privilégiées avec facteurs résistants à l'hameçonnage
IAM-03	Cycle de vie des accès, y compris prestataires et personnel PEO	R-08, R-01	Responsable Identités et Accès / RH	Trimestrielle	% de départs désactivés sous 24 h; % de comptes prestataires/PEO recertifiés
IAM-04	Identités machines, jetons et secrets	R-01, R-13, R-06	Sécurité des plateformes	Trimestrielle	% d'identités machines avec propriétaire et expiration; Âge moyen des secrets
SSC-01	Intégrité du build et des releases	R-03	VP Ingénierie / Ingénierie de release	Trimestrielle	% d'artefacts de release avec provenance vérifiable (cible 100 %); % de changements impactant la release approuvés à deux personnes
SSC-02	Gouvernance des contributeurs et des dépendances	R-03	VP Ingénierie / Sécurité produit	Trimestrielle	% de mainteneurs avec MFA résistant à l'hameçonnage; % de dépendances épinglées et couvertes par SBOM
SSC-03	Gestion des vulnérabilités, divulgation et publication de correctifs	R-02, R-10	VP Sécurité produit	Mensuelle	Délai médian de correction des Critiques (jours); Délai entre correctif et avis client
SSC-04	Développement sécurisé des composants à haut risque	R-02, R-06, R-09	VP Ingénierie / Sécurité produit	Trimestrielle	% de composants à haut risque avec modèle de menaces à jour; Vulnérabilités Critiques/Élevées trouvées en interne vs signalées en externe
SSC-05	Accompagnement des mises à niveau et versions supportées	R-10	VP Sécurité produit / Support	Trimestrielle	% d'instances auto-hébergées sur des versions supportées; Délai médian en jours entre correctif et adoption par le client
CLD-01	Socle de sécurité cloud	R-04, R-01	Sécurité cloud	Semestrielle	% de comptes cloud conformes au socle; Délai moyen de correction d'une mauvaise configuration critique
CLD-02	Isolation des tenants et plan de contrôle Dedicated	R-07	Directeur Ingénierie Dedicated	Semestrielle	Test indépendant des chemins inter-tenants réalisé (annuel); % d'actions opérateur approuvées JIT et journalisées
CLD-03	Isolation des runners et de l'exécution CI/CD	R-09	Directeur Plateforme Runners	Semestrielle	% de jobs sur runners partagés en isolation à usage unique; Incidents d'abus détectés/bloqués par trimestre

ID	Exigence	Risques traités	Responsable (proposé)	Revue	Principaux indicateurs
CLD-04	Protection des données, résidence et chiffrement	R-01, R-04	DPO / Sécurité cloud	Annuelle	% de stockages de données avec chiffrement et rotation de clés approuvés; Revues d'accès des administrateurs de clés réalisées
AI-01	Gouvernance de l'IA et modélisation des menaces	R-06	Responsable Sécurité de l'IA	Trimestrielle	% de fonctions d'IA avec modèle de menaces à jour; Taux de réussite des tests d'injection de prompt
AI-02	Privilèges des agents, périmètre des jetons et traitement des sorties	R-06	Responsable Sécurité de l'IA	Trimestrielle	% de jetons d'agent avec périmètre minimal appliqué; % d'actions sensibles d'agent exigeant une approbation
AI-03	Dépendance aux fournisseurs d'IA et de modèles	R-04, R-06	Responsable Risques tiers / Plateforme IA	Semestrielle	% de fournisseurs d'IA avec évaluation à jour; Temps de bascule vers un modèle alternatif (testé)
RES-01	Continuité d'activité et reprise après sinistre	R-05	VP Infrastructure	Trimestrielle	% de services critiques avec RTO/RPO testés; Dernier test de reprise régionale de bout en bout (jours)
RES-02	Intégrité des sauvegardes et assurance de restauration	R-05	VP Infrastructure / Stockage	Trimestrielle	% de jeux de données critiques avec copie immuable; Taux de réussite des tests de restauration
RES-03	Réponse aux incidents et communication client	R-02, R-05, R-10	Opérations de sécurité / Juridique / Communication	Semestrielle	Délai moyen de détection / confinement / notification; Exercices réalisés par an
MON-01	Journalisation, surveillance et couverture de détection	R-01, R-02, R-03	Opérations de sécurité	Trimestrielle	% de systèmes critiques alimentant le SIEM; % de chemins d'attaque prioritaires avec détections testées
MON-02	Renseignement sur la menace et chasse proactive	R-01, R-02	Gestion de la menace et des vulnérabilités	Mensuelle	Délai entre signal KEV/exploit et action; Chasses réalisées par trimestre
TPM-01	Assurance des tiers et sous-traitants	R-04, R-08	Responsable Risques tiers	Semestrielle	% de tiers critiques évalués sur les 12 derniers mois; Constats critiques ouverts en retard
TPM-02	Concentration sur le cloud et les fournisseurs critiques	R-04, R-05	Responsable Risques tiers / VP Infrastructure	Annuelle	% de services critiques avec plan de sortie/mode dégradé documenté; Dernière revue de concentration (jours)
PPL-01	Vérification des collaborateurs et sensibilisation à la sécurité	R-08, R-01	RH / Sensibilisation à la sécurité	Annuelle	% du personnel avec formation à jour; Taux d'échec aux simulations d'hameçonnage
PPL-02	Gestion du risque interne	R-08	Assurance sécurité / Juridique / RH	Semestrielle	Alertes d'activité privilégiée triées dans le SLA; Exceptions à la séparation des tâches
TRN-01	Transparence responsable	R-13	Responsable Assurance sécurité	Semestrielle	Incidents de données sensibles dans le contenu public par trimestre; Délai moyen de retrait et de rotation
CMP-01	Portefeuille de certifications et transitions de normes	R-12	Directeur Conformité sécurité	Annuelle	% de certifications renouvelées avant expiration; Déclarations publiques rapprochées du périmètre du certificat (O/N)
CMP-02	Transparence de l'assurance client	R-12, R-10	Assurance sécurité	Semestrielle	Délai médian de traitement d'une demande d'assurance; Fraîcheur des éléments (ancienneté du plus ancien)

8. Analyse d'écarts

Chaque exigence est comparée à ce que GitLab démontre publiquement. Le résultat est une carte de la *démontrabilité externe*, pas un verdict sur la sécurité de GitLab.

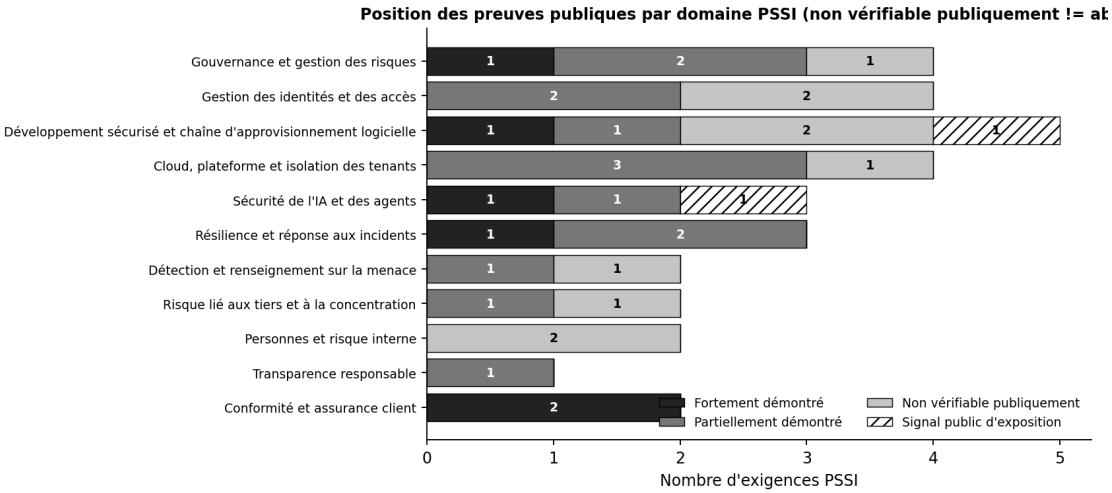


Figure 6 - Position des preuves par domaine PSSI.

Règle de lecture

Non vérifiable publiquement ne signifie PAS absent. « Signal public d'exposition » ne signifie PAS que la mesure manque : cela signifie que des événements publics montrent une exposition résiduelle que l'exigence vise à traiter.

Exig.	Exigence	Évaluation	Preuves publiques trouvées	Observation / écart	Preuves
GOV-01	Leadership et responsabilité de la sécurité	Partiellement démontré	L'Item 1C du 10-K décrit un programme piloté par le RSSI avec plus de 120 praticiens et une supervision du comité d'audit. Le RSSI est parti le 26 févr. 2026 ; le VP Opérations de sécurité assure l'intérim pendant la recherche.	La structure de gouvernance est claire ; la continuité du leadership est un risque de transition. L'effet sur la responsabilité des risques et le parrainage de la feuille de route n'est pas visible de l'extérieur.	E-03, E-04, E-31
GOV-02	Intégration de la gestion des risques	Partiellement démontré	Le 10-K indique que les risques identifiés sont évalués, priorisés et intégrés à un programme ERM piloté par l'Audit interne ; la FAQ du Trust Center traite de l'ERM.	La méthode, les échelles et la quantification ne sont pas publiques ; les critères d'acceptation ne peuvent pas être vérifiés.	E-03, E-05
GOV-03	Gestion des politiques et des exceptions	Fortement démontré	La politique de gestion des accès est un document contrôlé public avec propriétaires de code, un processus d'exception et des références de contrôles ; le Trust Center liste d'autres politiques (journalisation d'audit, usage acceptable).	Solides preuves documentaires ; volumes et ancienneté des exceptions non visibles.	E-16, E-05
GOV-04	Indicateurs de sécurité et reporting au conseil	Non vérifiable publiquement	Le comité d'audit « se réunit régulièrement avec la direction » sur le risque cyber ; escalade au conseil des incidents potentiellement significatifs.	Le contenu, la cadence et l'efficacité du reporting ne sont pas vérifiables publiquement.	E-03
IAM-01	Accès privilégiés	Partiellement démontré	La politique publique exige des demandes d'accès approuvées, une revue du moindre privilège, des revues, le retrait des droits au départ/transfert et un processus d'exception.	Contrôles spécifiques aux accès privilégiés, fréquence de revue, usage du JIT et indicateurs de couverture non publiés. L'efficacité n'est démontrée que par l'existence de SOC 2.	E-16, E-17, E-05
IAM-02	Authentification des collaborateurs	Non vérifiable publiquement	GitLab propose MFA/SSO à ses clients et décrit un déploiement du MFA par défaut pour son produit ; les standards d'authentification des collaborateurs ne sont pas publiés. Des données de notation externe signalent des détections d'infostealers (indicateur seulement).	Le type de MFA interne, la liaison de session et la posture des appareils ne sont pas vérifiables publiquement.	E-18, E-29
IAM-03	Cycle de vie des accès, y compris prestataires et personnel PEO	Partiellement démontré	La politique indique que les accès sont retirés à la cessation d'emploi et ajustés lors d'un transfert ; le 10-K décrit des engagements directs, PEO et prestataires.	La parité des mesures entre types d'engagement et le niveau d'automatisation ne sont pas vérifiables publiquement.	E-16, E-01
IAM-04	Identités machines, jetons et secrets	Non vérifiable publiquement	GitLab documente les bonnes pratiques de jetons et secrets pour ses clients et propose la détection de secrets comme fonction produit ; la gouvernance interne des identités machines n'est pas décrite publiquement.	Couverture et indicateurs d'hygiène internes non vérifiables publiquement. Les correctifs de septembre 2026 incluent une faille d'application du périmètre des jetons MCP.	E-34, E-26
SSC-01	Intégrité du build et des releases	Non vérifiable publiquement	Des releases mensuelles sur 172 mois consécutifs et la transparence open-core sont documentées ; les mesures de provenance, de signature et d'approbation de release n'ont pas été trouvées dans les sources publiques examinées.	Non vérifiable publiquement. Une compromission de la chaîne d'approvisionnement étant un événement à impact Critique, l'absence d'assurance publique est en soi un constat pour les clients.	E-01, E-02
SSC-02	Gouvernance des contributeurs et des dépendances	Non vérifiable publiquement	Le 10-K fait état de plus de 5 200 contributeurs et cite l'exposition de la chaîne d'approvisionnement open source comme risque significatif ; les détails des mesures ne sont pas publics.	Non vérifiable publiquement.	E-01, E-02
SSC-03	Gestion des vulnérabilités, divulgation et publication de correctifs	Fortement démontré	Programme HackerOne, security.txt, CVE avec CWE, politique de maintenance publiée, releases de correctifs mensuelles et critiques ; GitLab.com corrigé au moment de la release pour les failles de septembre 2026.	Le processus est fortement démontré ; les indicateurs de résultat (respect des SLA) ne sont pas publiés.	E-18, E-19, E-22
SSC-04	Développement sécurisé des composants à haut risque	Signal public d'exposition	Des failles critiques dans les releases récentes incluent une traversée de chemin non authentifiée (CVSS 10, inscrite KEV), une désérialisation atteignable via Duo Chat et des RCE dans les parseurs CI/CD ; CVE-2023-7028 a été inscrite KEV en 2024.	Signal public d'exposition résiduelle dans les composants à haut risque. Cela n'établit pas que les mesures de développement sécurisé sont absentes : de grands produits livrent couramment de tels défauts, et la correction rapide est visible.	E-22, E-23, E-26, E-32

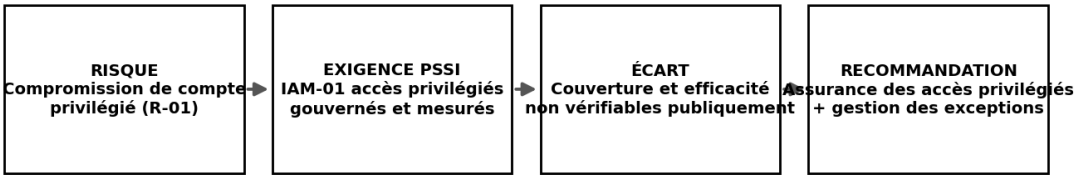
Exig.	Exigence	Évaluation	Preuves publiques trouvées	Observation / écart	Preuves
SSC-05	Accompagnement des mises à niveau et versions supportées	Partiellement démontré	La politique de maintenance est publiée ; des données de 2024 montraient des milliers d'instances non corrigées des semaines après une faille KEV ; les correctifs de 2026 ont été rétroportés vers des branches en fin de vie.	La politique existe ; les résultats d'adoption dépendent des clients et ne sont pas publiés.	E-18, E-21, E-25
CLD-01	Socle de sécurité cloud	Partiellement démontré	ISO 27017 et SOC 2 couvrent les services cloud ; GCP et AWS sont les fournisseurs d'hébergement déclarés.	Les spécificités du socle et les indicateurs de posture ne sont pas publics.	E-05, E-09
CLD-02	Isolation des tenants et plan de contrôle Dedicated	Partiellement démontré	Dedicated utilise des comptes AWS par tenant dans des VPC isolés, un plan de contrôle Switchboard, la reprise Geo et PrivateLink optionnel ; FedRAMP Moderate pour Government et SOC 2 pour Dedicated.	La conception est solide ; le modèle d'accès au plan de contrôle et les résultats de tests ne sont pas détaillés publiquement.	E-10, E-11, E-06
CLD-03	Isolation des runners et de l'exécution CI/CD	Non vérifiable publiquement	Le 10-K reconnaît le risque accru lié à l'exécution de code client et mentionne des mesures d'atténuation comme les limites de l'offre gratuite.	Non vérifiable publiquement au niveau des mesures.	E-02
CLD-04	Protection des données, résidence et chiffrement	Partiellement démontré	ISO 27018 couvre les données personnelles dans le cloud ; Dedicated permet le choix de la région et des copies de sauvegarde dans d'autres régions au choix.	Le modèle de gestion des clés (clés gérées par le client, HSM) n'est pas vérifié dans les sources examinées.	E-05, E-11
AI-01	Gouvernance de l'IA et modélisation des menaces	Fortement démontré	La certification ISO/IEC 42001 et un AI Transparency Center sont listés ; un fournisseur de protection contre l'injection de prompt est un sous-traitant déclaré.	La gouvernance est démontrée de façon indépendante ; l'efficacité face aux nouvelles classes d'attaques ne l'est pas.	E-05, E-09, E-27
AI-02	Privilèges des agents, périmètre des jetons et traitement des sorties	Signal public d'exposition	Des chercheurs ont démontré l'exfiltration de code privé via Duo (2025) ; les correctifs de septembre 2026 corrigent une faille CVSS 9,9 atteignable via l'accès à Duo Chat et une faiblesse d'application du périmètre MCP.	Signal public d'exposition sur une surface d'attaque en expansion ; aucune inférence sur l'exhaustivité des mesures.	E-26, E-27, E-23
AI-03	Dépendance aux fournisseurs d'IA et de modèles	Partiellement démontré	La liste des sous-traitants nomme plusieurs fournisseurs de modèles/cloud ; le 10-K indique qu'une perturbation ou un changement de conditions des fournisseurs pourrait affecter les fonctions d'IA et met en avant la neutralité vis-à-vis des LLM et les passerelles auto-hébergées comme éléments différenciants.	Les tests de secours et les conditions de traitement des données ne sont pas publics.	E-02, E-09, E-01
RES-01	Continuité d'activité et reprise après sinistre	Partiellement démontré	Des Game Days trimestriels, des sauvegardes multi-régions et des objectifs (p. ex. RTO 2 h / RPO 1 h pour la cellule primaire) sont documentés ; les documents de conception indiquent que la reprise régionale n'était pas encore validée de bout en bout et que GitLab.com s'exécute depuis une seule région.	La documentation est ouverte et franche ; l'état actuel de validation est incertain et a pu progresser.	E-12, E-13, E-14, E-15
RES-02	Intégrité des sauvegardes et assurance de restauration	Fortement démontré	Des tests de restauration quotidiens automatisés des bases applicatives dans des pipelines CI et un stockage de sauvegarde multi-régions sont documentés ; un document de conception pose l'exigence que l'identité de reprise ne puisse pas supprimer les sauvegardes.	Solides preuves de tests de restauration ; l'immutabilité et la séparation pour tous les jeux de données ne sont pas confirmées.	E-12
RES-03	Réponse aux incidents et communication client	Partiellement démontré	Le 10-K décrit l'escalade des incidents potentiellement significatifs à la direction et au conseil et reconnaît les obligations de notification.	Playbooks, cadence d'exercices et indicateurs de délai non publics.	E-03, E-02
MON-01	Journalisation, surveillance et couverture de détection	Partiellement démontré	Une politique de journalisation d'audit est listée sur le Trust Center ; le 10-K mentionne l'analyse comportementale, la détection et la réponse automatisées et une orientation zero-trust.	Couverture et qualité de détection non vérifiables publiquement.	E-05, E-02
MON-02	Renseignement sur la menace et chasse proactive	Non vérifiable publiquement	Aucune description publique du programme de renseignement sur la menace n'a été trouvée dans les sources examinées.	Non vérifiable publiquement.	E-29, E-32

Exig.	Exigence	Évaluation	Preuves publiques trouvées	Observation / écart	Preuves
TPM-01	Assurance des tiers et sous-traitants	Partiellement démontré	Liste publique de sous-traitants avec lieux, services et notifications de changement ; le 10-K reconnaît les attentes de diligence raisonnable.	Profondeur d'évaluation et surveillance non publiques.	E-09, E-02
TPM-02	Concentration sur le cloud et les fournisseurs critiques	Non vérifiable publiquement	GitLab.com sur GCP et Dedicated sur AWS indiquent une diversité de fournisseurs entre produits ; l'exploitation mono-région de GitLab.com est décrite dans les documents de conception.	Les analyses de concentration et plans de sortie ne sont pas publics.	E-12, E-10, E-01
PPL-01	Vérification des collaborateurs et sensibilisation à la sécurité	Non vérifiable publiquement	Le modèle de télétravail et l'engagement PEO/prestataires sont déclarés ; les détails de vérification et de sensibilisation n'ont pas été trouvés.	Non vérifiable publiquement.	E-01
PPL-02	Gestion du risque interne	Non vérifiable publiquement	La politique d'accès mentionne approbations et revues ; aucune description d'un programme de risque interne n'a été trouvée.	Non vérifiable publiquement.	E-16
TRN-01	Transparence responsable	Partiellement démontré	Le 10-K indique que GitLab promeut une transparence « responsable » et sensibilise son personnel ; le handbook comporte une section interne pour les contenus sensibles.	Les garde-fous techniques ne sont pas documentés publiquement.	E-02
CMP-01	Portefeuille de certifications et transitions de normes	Fortement démontré	SOC 2 Type 2 (Sécurité, Confidentialité, Disponibilité), SOC 3 pour GitLab.com, ISO 27001/27017/27018, ISO 42001, FedRAMP Moderate pour Dedicated for Government ; FedRAMP High en perspective.	Portefeuille solide. D'anciennes pages publiques citent encore ISO 27001:2013 ; les certificats ISO 27001:2013 ont expiré après l'échéance de transition du 31 oct. 2025, les pages publiques devraient donc être rapprochées du certificat en vigueur.	E-05, E-06, E-07, E-08, E-30
CMP-02	Transparence de l'assurance client	Fortement démontré	Le Trust Center propose rapports SOC, lettre de continuité, certificat ISO en plusieurs langues, synthèse de test d'intrusion, politiques, FAQ et centre de transparence de l'IA.	Solide ; pourrait ajouter des indicateurs de résultat (délai de correction, résultats des tests de reprise).	E-05, E-09

9. Plan d'amélioration de la sécurité

La chaîne utilisée dans tout le document est **Risque -> Exigence PSSI -> Écart -> Recommandation**.

Exemple illustré de la logique du plan d'amélioration



-> Actions A-05 (inventaire), A-04 (MFA), A-21 (JIT) -> indicateur : % de comptes privilégiés avec MFA résistant à l'hameçonnage

Ci-dessous, la chaîne est présentée pour les risques Critiques et Élevés (la chaîne complète des 13 risques figure dans l'onglet Risques_vers_Actions du livrable 4).

R-01 - Compromission d'identité privilégiée (20, Critique)

Étape	Contenu
Risque	Compromission d'identités de collaborateurs ou d'administration (y compris vol de session/jeton) donnant accès à la production, aux organisations cloud, aux opérateurs Dedicated ou aux éléments de signature.
Exigences PSSI	IAM-01 Accès privilégiés, IAM-02 Authentification des collaborateurs, IAM-04 Identités machines, jetons et secrets, MON-01 Journalisation, surveillance et couverture de détection
Position de l'écart	IAM-01 (Partiellement démontré) ; IAM-02 (Non vérifiable publiquement) ; IAM-04 (Non vérifiable publiquement) ; MON-01 (Partiellement démontré)
Recommandation	Inventaire des accès privilégiés Tier-0 ; MFA résistant à l'hameçonnage et sessions courtes ; élévation juste-à-temps ; hygiène des identités machines ; détection d'activité privilégiée anormale.
Actions de la feuille de route	A-01, A-04, A-05, A-09, A-10, A-11, A-12, A-16, A-21

R-02 - Exploitation de vulnérabilités produit critiques (20, Critique)

Étape	Contenu
Risque	Une faille critique de GitLab (lecture de fichier pré-auth, désérialisation, RCE CI/CD) est exploitée contre GitLab.com, Dedicated ou la base auto-hébergée.
Exigences PSSI	SSC-03 Gestion des vulnérabilités, divulgation et publication de correctifs, SSC-04 Développement sécurisé des composants à haut risque, RES-03 Réponse aux incidents et communication client
Position de l'écart	SSC-03 (Fortement démontré) ; SSC-04 (Signal public d'exposition) ; RES-03 (Partiellement démontré)
Recommandation	Réponse aux vulnérabilités critiques plus rapide et répétée ; durcissement du développement sécurisé des composants à haut risque (authz, parseurs, interpréteurs CI/CD) ; réduction d'exposition en périphérie SaaS ; playbook KEV.
Actions de la feuille de route	A-02, A-03, A-06, A-08, A-16, A-17, A-22

R-03 - Compromission de la chaîne d'approvisionnement logicielle du produit GitLab (15, Élevé)

Étape	Contenu
Risque	Du code ou un artefact malveillant est introduit via les contributeurs, dépendances, build ou infrastructure de release.
Exigences PSSI	SSC-01 Intégrité du build et des releases, SSC-02 Gouvernance des contributeurs et des dépendances, IAM-01 Accès privilégiés
Position de l'écart	SSC-01 (Non vérifiable publiquement) ; SSC-02 (Non vérifiable publiquement) ; IAM-01 (Partiellement démontré)
Recommandation	Provenance et signature vérifiables des builds, builders éphémères hermétiques, approbation de release à deux personnes, comptes de mainteneurs durcis, gouvernance des dépendances.
Actions de la feuille de route	A-09, A-19

R-05 - Interruption majeure de service ou perte de données (15, Élevé)

Étape	Contenu
Risque	Panne prolongée de GitLab.com, attaque destructrice ou défaillance régionale avec reprise lente ou incomplète.
Exigences PSSI	RES-01 Continuité d'activité et reprise après sinistre, RES-02 Intégrité des sauvegardes et assurance de restauration, RES-03 Réponse aux incidents et communication client
Position de l'écart	RES-01 (Partiellement démontré) ; RES-02 (Fortement démontré) ; RES-03 (Partiellement démontré)
Recommandation	Tests de reprise régionale de bout en bout, sauvegardes immuables inter-comptes, réduction du rayon d'impact (cellules), attestation publique des RTO/RPO.
Actions de la feuille de route	A-13, A-18, A-23

R-06 - Détournement des fonctions d'IA et des agents (16, Élevé)

Étape	Contenu
Risque	Injection de prompt, agents/jetons sur-privilégiés ou faiblesses de la chaîne d'approvisionnement de l'IA conduisent à des fuites de données ou modifications de code malveillantes.
Exigences PSSI	AI-01 Gouvernance de l'IA et modélisation des menaces, AI-02 Privilèges des agents, périmètre des jetons et traitement des sorties, AI-03 Dépendance aux fournisseurs d'IA et de modèles
Position de l'écart	AI-01 (Fortement démontré) ; AI-02 (Signal public d'exposition) ; AI-03 (Partiellement démontré)
Recommandation	Modélisation des menaces de l'IA, jetons d'agents et MCP au moindre privilège, approbation humaine des actions sensibles, durcissement des canaux de sortie, red teaming continu de l'IA.
Actions de la feuille de route	A-03, A-14, A-22

R-10 - Écart d'adoption des correctifs exposant les clients auto-hébergés et la réputation de GitLab (16, Élevé)

Étape	Contenu
Risque	Les clients ne corrigent pas (ou exécutent des versions non supportées) après divulgation, entraînant une exploitation de masse et une atteinte à la réputation de GitLab.
Exigences PSSI	SSC-03 Gestion des vulnérabilités, divulgation et publication de correctifs, SSC-05 Accompagnement des mises à niveau et versions supportées, CMP-02 Transparence de l'assurance client
Position de l'écart	SSC-03 (Fortement démontré) ; SSC-05 (Partiellement démontré) ; CMP-02 (Fortement démontré)
Recommandation	Normes d'avis aux clients, politique de versions supportées, incitations fondées sur la télémétrie, publication d'indicateurs de délai de correction.

Étape	Contenu
Actions de la feuille de route	A-02, A-08, A-17

10. Feuille de route de sécurité

Les actions sont priorisées selon le risque, l'urgence et l'effort, séquencées selon les dépendances et phasées sur 24 mois. Les responsables sont des rôles proposés.

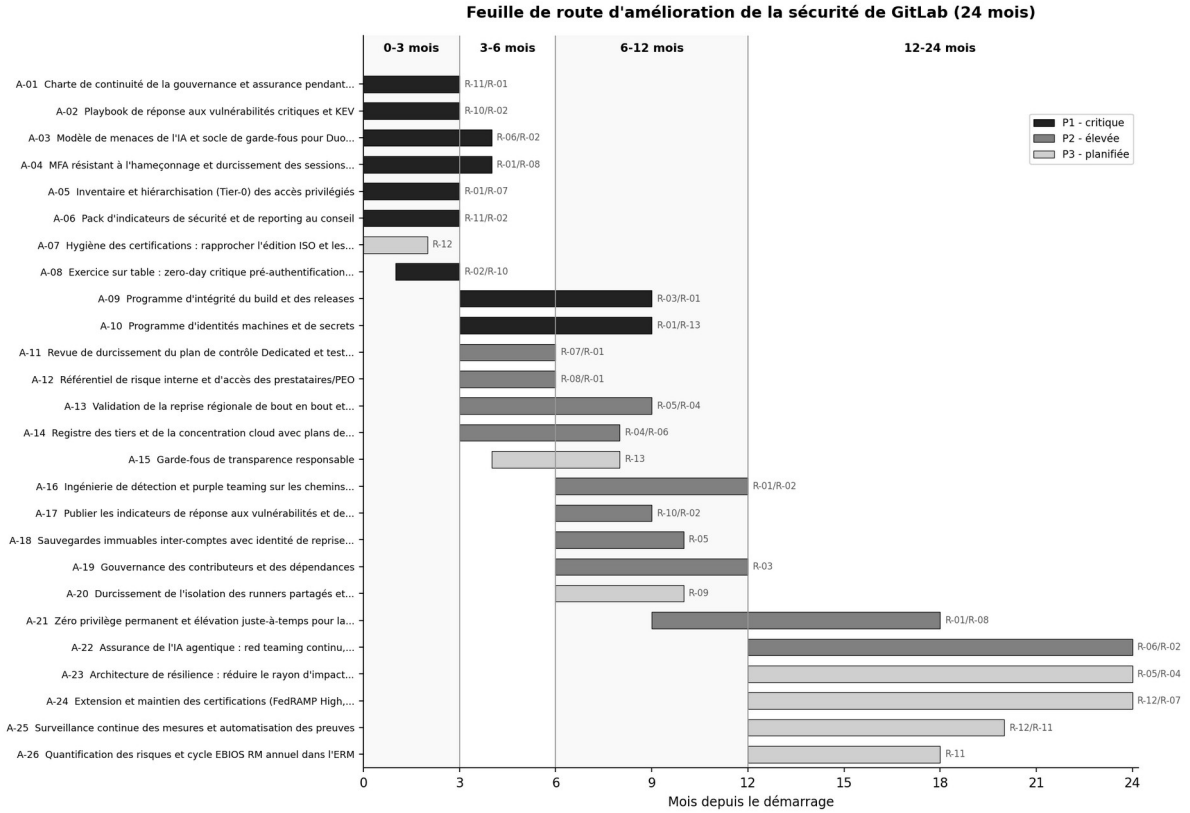


Figure 7 - Feuille de route sur 24 mois (P1 noir foncé, P2 gris, P3 gris clair).

ID	Action	Prio	Risque	Responsable proposé	Mois	Dépendances	Mesure de succès
A-01	Charte de continuité de la gouvernance et assurance pendant l'intérim	P1	R-11/R-01	Président du comité d'audit / DG avec le RSSI par intérim	1-3	None	Charte approuvée ; responsables nommés pour tous les risques Critiques/Élevés
A-02	Playbook de réponse aux vulnérabilités critiques et KEV	P1	R-10/R-02	VP Sécurité produit avec Support et Communication	1-3	None	Playbook approuvé ; délai cible entre correctif et avis défini et tenu
A-03	Modèle de menaces de l'IA et socle de garde-fous pour Duo Agent Platform et les périmètres MCP	P1	R-06/R-02	Responsable Sécurité de l'IA	1-4	None	Modèle de menaces approuvé ; 100 % des jetons d'agent à périmètre appliqué
A-04	MFA résistant à l'hameçonnage et durcissement des sessions pour les accès privilégiés et de production	P1	R-01/R-08	Responsable Identités et Accès / IT	1-4	A-05	100 % des connexions privilégiées résistantes à l'hameçonnage ; durée de session Tier-0 réduite
A-05	Inventaire et hiérarchisation (Tier-0) des accès privilégiés	P1	R-01/R-07	Responsable Identités et Accès	1-3	None	100 % des comptes Tier-0 inventoriés et attribués à un propriétaire
A-06	Pack d'indicateurs de sécurité et de reporting au conseil	P1	R-11/R-02	Responsable Gouvernance de la sécurité	1-3	None	Premier pack trimestriel livré ; tous les indicateurs ont cible et responsable
A-07	Hygiène des certifications : rapprocher l'édition ISO et les déclarations de périmètre publiques	P3	R-12	Directeur Conformité sécurité	1-2	None	Toutes les pages publiques cohérentes avec l'édition du certificat
A-08	Exercice sur table : zero-day critique pré-authentification sur GitLab.com, Dedicated et auto-hébergé	P1	R-02/R-10	Opérations de sécurité / Continuité d'activité	2-3	A-02	Exercice réalisé ; actions consignées et suivies
A-09	Programme d'intégrité du build et des releases	P1	R-03/R-01	VP Ingénierie / Ingénierie de release	4-9	A-05	100 % des artefacts de release avec provenance ; attestation publique
A-10	Programme d'identités machines et de secrets	P1	R-01/R-13	Sécurité des plateformes	4-9	A-05	95 %+ des identités machines avec propriétaire et expiration
A-11	Revue de durcissement du plan de contrôle Dedicated et test d'intrusion indépendant inter-tenants	P2	R-07/R-01	Directeur Ingénierie Dedicated / Sécurité	4-6	A-05	Test réalisé ; constats critiques corrigés dans le SLA
A-12	Référentiel de risque interne et d'accès des prestataires/PEO	P2	R-08/R-01	RH / Responsable Identités et Accès	4-6	A-05	Parité des mesures démontrée pour tous les types d'engagement
A-13	Validation de la reprise régionale de bout en bout et attestation des RTO/RPO	P2	R-05/R-04	VP Infrastructure	4-9	None	RTO/RPO mesurés dans la cible ; répétition annuelle planifiée
A-14	Registre des tiers et de la concentration cloud avec plans de mode dégradé et de sortie	P2	R-04/R-06	Responsable Risques tiers / Achats	4-8	None	Plans pour tous les fournisseurs critiques ; une bascule testée
A-15	Garde-fous de transparence responsable	P3	R-13	Responsable Assurance sécurité	5-8	None	Aucun secret non corrigé > 24 h dans le contenu public
A-16	Ingénierie de détection et purple teaming sur les chemins d'attaque prioritaires	P2	R-01/R-02	Opérations de sécurité	7-12	A-04	80 % des chemins d'attaque prioritaires avec détections testées
A-17	Publier les indicateurs de réponse aux vulnérabilités et de délai de correction	P2	R-10/R-02	VP Sécurité produit / Assurance sécurité	7-9	A-02, A-06	Indicateurs publiés chaque trimestre
A-18	Sauvegardes immuables inter-comptes avec identité de reprise distincte	P2	R-05	VP Infrastructure / Stockage	7-10	A-13	100 % des jeux de données critiques avec copie immuable
A-19	Gouvernance des contributeurs et des dépendances	P2	R-03	VP Ingénierie / Sécurité produit	7-12	A-09	100 % des mainteneurs avec MFA résistant à l'hameçonnage ; couverture SBOM > 90 %

ID	Action	Prio	Risque	Responsable proposé	Mois	Dépendances	Mesure de succès
A-20	Durcissement de l'isolation des runners partagés et analytique d'abus	P3	R-09	Directeur Plateforme Runners	7-10	None	Tests d'isolation réussis ; délai moyen de suspension des abus défini
A-21	Zéro privilège permanent et élévation juste-à-temps pour la production	P2	R-01/R-08	Responsable Identités et Accès / SRE	10-18	A-05, A-04	90 % des accès de production via JIT
A-22	Assurance de l'IA agentique : red teaming continu, nomenclature IA, policy-as-code	P2	R-06/R-02	Responsable Sécurité de l'IA	13-24	A-03	Cycles de red team trimestriels ; aucun constat critique d'agent ouvert > 30 jours
A-23	Architecture de résilience : réduire le rayon d'impact (cellules, multi-région pour les services critiques)	P3	R-05/R-04	VP Infrastructure	13-24	A-13	Les services critiques reprennent dans une seconde région dans la cible
A-24	Extension et maintien des certifications (FedRAMP High, surveillance ISO 42001)	P3	R-12/R-07	Directeur Conformité sécurité	13-24	A-25	Jalon d'autorisation FedRAMP High atteint
A-25	Surveillance continue des mesures et automatisation des preuves	P3	R-12/R-11	Directeur Conformité sécurité	13-20	A-06	70 % des mesures testées automatiquement
A-26	Quantification des risques et cycle EBIOS RM annuel dans l'ERM	P3	R-11	RSSI / Audit interne	13-18	A-06	Cycle annuel réalisé ; 5 principaux risques quantifiés

Synthèse du phasage

Phase	Orientation	Actions
0-3 mois	Actions critiques de gouvernance et de risque : continuité de la gouvernance, accès privilégiés Tier-0, MFA résistant à l'hameçonnage, playbook KEV et exercice sur table, modèle de menaces de l'IA, pack d'indicateurs	A-01, A-02, A-03, A-04, A-05, A-06, A-07, A-08
3-6 mois	Améliorations de mesures prioritaires : intégrité des releases, identités machines, plan de contrôle Dedicated, validation de la reprise, tiers	A-09, A-10, A-11, A-12, A-13, A-14, A-15
6-12 mois	Mise en œuvre et automatisation : ingénierie de détection, publication d'indicateurs, sauvegardes, dépendances, runners, JIT	A-16, A-17, A-18, A-19, A-20, A-21
12-24 mois	Maturité stratégique : assurance de l'IA agentique, architecture de résilience, certifications, automatisation des mesures, quantification des risques	A-22, A-23, A-24, A-25, A-26

11. Conclusion et prochaines étapes

GitLab se présente comme une organisation mature en sécurité et d'une transparence inhabituelle. Les risques qui comptent le plus sont ceux inhérents à sa position : des identités privilégiées puissantes, une plateforme d'exécution de code et de livraison logicielle soumise à une pression continue de vulnérabilités, une nouvelle surface d'attaque liée aux agents d'IA, et une posture de résilience dont la validation régionale de bout en bout n'est pas démontrée publiquement. La transition de direction est un facteur de calendrier qui rend les 90 premiers jours de la feuille de route particulièrement précieux.

Prochaines étapes

5. Valider les scores d'impact et de vraisemblance avec les données internes de GitLab (historique d'incidents, télémétrie, résultats de tests).
6. Convertir les éléments « non vérifiables publiquement » en éléments confirmés ou ouverts par une demande d'assurance client (Trust Center, rapport SOC 2 sous NDA).
7. Revoir la PSSI avec les responsables sécurité, ingénierie et juridique ; convenir des indicateurs et des valeurs de référence.
8. Lancer les actions à 0-3 mois et refaire l'actualisation du registre de preuves dans six mois.

Annexe A - Matrice de traçabilité

Risque	Scénario stratégique	Scénario opérationnel	Événements redoutés	Exigences PSSI	Actions
R-01	SS-01	OS-01	ER-08, ER-01	IAM-01, IAM-02, IAM-04, MON-01	A-01, A-04, A-05, A-09, A-10, A-11, A-12, A-16, A-21
R-02	SS-03	OS-03	ER-01, ER-07	SSC-03, SSC-04, RES-03	A-02, A-03, A-06, A-08, A-16, A-17, A-22
R-03	SS-02	OS-02	ER-02	SSC-01, SSC-02, IAM-01	A-09, A-19
R-04	SS-04	OS-08	ER-03, ER-01	TPM-01, TPM-02	A-13, A-14, A-23
R-05	SS-07	OS-06	ER-03	RES-01, RES-02, RES-03	A-13, A-18, A-23
R-06	SS-05	OS-04	ER-05	AI-01, AI-02, AI-03	A-03, A-14, A-22
R-07	SS-06	OS-05	ER-04	CLD-02, IAM-01	A-05, A-11, A-24
R-08	SS-08	OS-09	ER-08, ER-01	IAM-03, PPL-01, PPL-02	A-04, A-12, A-21
R-09	SS-09	OS-07	ER-09	CLD-03	A-20
R-10	SS-03	OS-03	ER-07	SSC-03, SSC-05, CMP-02	A-02, A-08, A-17
R-11	SS-10	-	ER-06	GOV-01, GOV-02, GOV-04	A-01, A-06, A-25, A-26
R-12	SS-10	-	ER-06	CMP-01, GOV-03	A-07, A-24, A-25
R-13	SS-11	OS-10	ER-10	TRN-01, IAM-04	A-10, A-15

Annexe B - Synthèse du registre de preuves

ID	Source	Fiab.	Date
E-01	GitLab Inc. Formulaire 10-K (exercice clos le 31 janv. 2026) - Item 1 Activité	A	2026-03-17
E-02	GitLab Inc. Formulaire 10-K (FY2026) - Item 1A Facteurs de risque	A	2026-03-17
E-03	GitLab Inc. Formulaire 10-K (FY2026) - Item 1C Cybersécurité	A	2026-03-17
E-04	GitLab Inc. Formulaire 10-K (FY2025) - gouvernance	A	2025-03-21
E-05	Trust Center de GitLab	A	Consulté le 2026-10-04
E-06	Handbook GitLab - Audits externes, certifications et attestations	A	Consulté le 2026-10-04
E-07	Handbook GitLab - Certifications de sécurité Dedicated	B	Consulté le 2026-10-04
E-08	Communiqué de presse GitLab - extension du portefeuille de certifications et de rapports de sécurité	A	2023-01-26
E-09	Liste des sous-traitants de GitLab	A	Consulté le 2026-10-04
E-10	GitLab Docs - Architecture de GitLab Dedicated	A	Consulté le 2026-10-04
E-11	GitLab Docs (archive 16.7) - GitLab Dedicated	A	Archivé
E-12	Handbook GitLab - Reprise après sinistre de GitLab.com	A	Consulté le 2026-10-04
E-13	GitLab Docs - Plan directeur de reprise après sinistre de GitLab.com	B	Consulté le 2026-10-04
E-14	GitLab Docs (archive 17.0) - Reprise après sinistre Cells 1.0	B	Archivé
E-15	Handbook GitLab - SLA et plan de reprise de GitLab Dedicated	A	Consulté le 2026-10-04
E-16	Handbook GitLab - Politique de gestion des accès (document contrôlé)	A	Consulté le 2026-10-04
E-17	Handbook GitLab - Politique de gestion des accès (moindre privilège)	A	Consulté le 2026-10-04
E-18	Blog GitLab - Avancement de l'engagement Secure by Design	A	2025-06-09
E-19	GitLab - Processus de divulgation coordonnée	A	Consulté le 2026-10-04
E-20	The Hacker News - La CISA alerte sur l'exploitation active d'une faille de réinitialisation de mot de passe de GitLab	B	2024-05
E-21	SC Media - Faille de prise de contrôle de compte GitLab ajoutée au KEV	B	2024-05
E-22	GitLab Docs - Release de correctifs critiques 19.3.2, 19.2.6, 19.1.8	A	2026-09-10/11
E-23	CyberScoop - La faille critique de GitLab attire déjà des sondages à l'échelle d'Internet	B	2026-09-11
E-24	Hive Pro - Traversée de chemin de GitLab (CVE-2026-85706) exploitée pour voler des secrets	B	2026-09
E-25	InfoQ - Vulnérabilité de GitLab sous exploitation active	B	2026-10
E-26	daily.dev - Release de correctifs critiques GitLab 19.4.1, 19.3.3, 19.2.7	C	2026-09-23
E-27	The Hacker News - Vulnérabilité de GitLab Duo (recherche de Legit Security)	B	2025-05
E-28	HKCERT - Multiples vulnérabilités de GitLab	B	2026-09-14
E-29	UpGuard - Notation de sécurité et rapport de risque fournisseur de GitLab	C	Consulté le 2026-10-04
E-30	Built In - Offre d'emploi Senior Manager Security Compliance de GitLab	C	2026
E-31	board-cybersecurity.com - Suivi de la gouvernance de GitLab	C	2026-03-18
E-32	GCVE / enregistrement KEV de la CISA pour CVE-2023-7028	B	2024-05
E-33	SecurityOnline - La release de correctifs critiques de GitLab corrige de graves failles RCE	C	2026-09-23
E-34	GitLab Docs - Bonnes pratiques d'authentification et d'autorisation	A	Consulté le 2026-10-04
E-35	Blog GitLab - Principales fonctions de conformité à exploiter dans GitLab	A	2022-07-13
E-36	Blog GitLab - Quel est le niveau de sécurité de GitLab ? (SOC 2 et cadre de contrôle)	A	2020-06-24

Les assertions complètes, URL et limites figurent dans le livrable 5.

Annexe C - Glossaire

Terme	Signification
EBIOS RM	Expression des Besoins et Identification des Objectifs de Sécurité - Risk Manager (ANSSI)
PSSI	Politique de Sécurité des Systèmes d'Information
KEV	Catalogue des vulnérabilités exploitées connues de la CISA (Known Exploited Vulnerabilities)
PEO	Professional Employer Organisation (employeur de référence)
JIT	Accès privilégié juste-à-temps (just-in-time)
Tier-0	Actifs dont la compromission donne le contrôle de tout l'environnement (racines d'identité, racines d'organisation cloud, plans de contrôle, clés de signature)
SLSA	Supply-chain Levels for Software Artifacts - cadre de provenance
MCP	Model Context Protocol - interface d'outils utilisée par les agents d'IA
RTO / RPO	Durée maximale d'interruption admissible / perte de données maximale admissible
DIC	Disponibilité, Intégrité, Confidentialité
RSSI	Responsable de la sécurité des systèmes d'information